



Prepared by: Parashuram K, Rehanqamar, Himanshu.

Reviewed by: Sulabh Mishra

SQL

SQL (Structured Query Language) is a programming language used to manage data held in relational databases. It is a standard programming language for managing and manipulating data stored in relational database management systems (RDBMS).

SQL is used to create, modify, and delete databases and tables; insert, update, and delete data in databases; and create, modify, and delete views, stored procedures, and functions. It can also be used to create and execute queries to retrieve specific data from databases.

Here are some common SQL commands:

SELECT: used to retrieve data from a database

INSERT: used to insert data into a database

UPDATE: used to update existing data in a database

DELETE: used to delete data from a database

CREATE: used to create a new database or table

ALTER: used to modify an existing database or table

DROP: used to delete a database or table

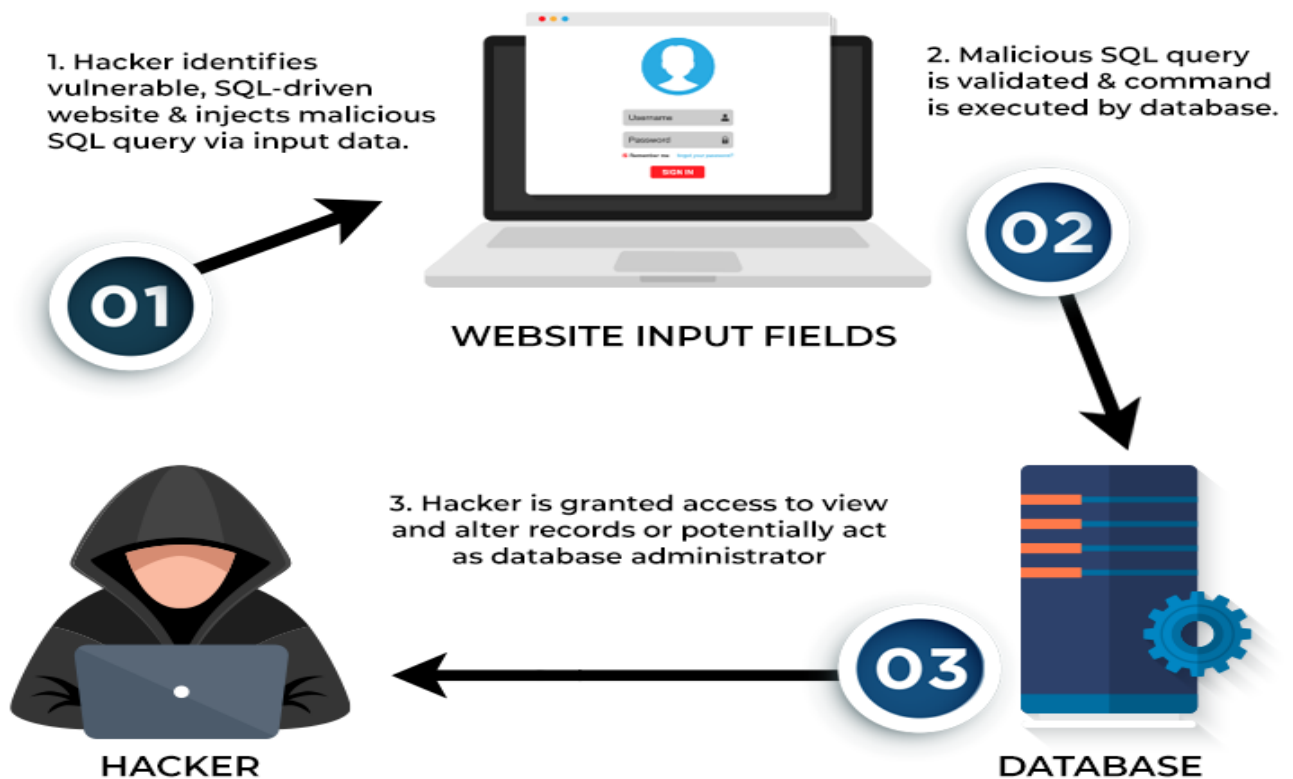
SQL INJECTION

SQL injection is a code injection technique that might destroy your database and

It is one of the most common web hacking techniques



FUNCTIONING OF AN SQL INJECTION



What is SQL injection attack?

SQL injection is a type of cyber attack in which an attacker inserts malicious code into a database through a website's input fields, such as login forms, search fields, and contact forms, to gain unauthorized access to sensitive data.

SQL injection attacks are possible when an application uses user-supplied input in the construction of an SQL query without properly sanitizing it first. This allows the attacker to send SQL commands to the database, which can be used to extract sensitive data, modify data, or even delete data.

HOW SQL INJECTION ATTACK LAUNCHED?

There are several ways that an attacker can launch an SQL injection attack. Here are a few common methods:

Form input fields: One of the most common ways that attackers use to launch an SQL injection attack is through form input fields on a website, such as login forms, search fields, and contact forms. By entering malicious code into these fields, the attacker can send commands to the database that can be used to extract sensitive data or perform other malicious actions.

Hidden fields: Attackers can also use hidden fields in forms to launch an SQL injection attack. Hidden fields are not visible to users, but they can be used to send data to the server. By using hidden fields to send malicious code to the server, an attacker can exploit vulnerabilities in the database.

URL parameters: Attackers can also use URL parameters to launch an SQL injection attack. URL parameters are values that are passed to a website through the URL. By manipulating these values, an attacker can



send malicious code to the server and exploit vulnerabilities in the database.

Cookies: Cookies are small pieces of data that are stored on a user's computer and are used to track user activity on a website. Attackers can manipulate cookies to launch an SQL injection attack by sending malicious code to the server through the cookie.

HTTP headers: HTTP headers are used to pass information between the client and the server. Attackers can manipulate HTTP headers to launch an SQL injection attack by sending malicious code to the server through the headers.

HOW TO MITIGATE SQL ATTACK?

There are several ways that you can mitigate the risk of an SQL injection attack:

Sanitize user input: One of the most effective ways to prevent SQL injection attacks is to sanitize all user-supplied input. This can be done by using prepared statements with parameterized queries, which allows you to separate data from the SQL code and helps prevent malicious code from being executed.

Use stored procedures: Stored procedures are pre-compiled SQL statements that are stored in the database and can be called by name. By using stored procedures, you can reduce the risk of SQL injection attacks because the SQL code is already compiled and stored in the database, so it is not possible for an attacker to inject malicious code into the SQL statement.



Validate input: Proper input validation is also important in preventing SQL injection attacks. This can be done by using regular expressions to validate user-supplied input and ensure that it conforms to a specific pattern.

Implement least privilege: It is important to implement the principle of least privilege, which means that users should only have the permissions and privileges that are necessary to perform their job duties. This helps reduce the risk of an SQL injection attack because it limits the actions that a user can perform on the database.

Keep software and applications up to date: It is important to keep all database software and applications up to date with the latest security patches. This helps prevent vulnerabilities that could be exploited by attackers.

By implementing these and other security measures, you can help protect your organization against SQL injection attacks

